AI Agent for DevOps Repository Auditing

Rayyan Qamar

Roll number: 23i-0815 | Section: A

MLOps & Production AI Engineering — Assignment 2

Implementation and results

The project is an unattended Python auditing agent. Gemini selects read-only inspection tools, interprets their results, and chooses follow-up calls. The application validates evidence and writes the required JSON report. No agent framework is used.

Tools: list_files, read_file, search_code and git_log. Targets are read through Git objects without checkout, dependency installation or execution of repository code.

Repository: https://github.com/bravocodes145/devops-audit-agent

Report generated (UTC): 2026-10-25 09:46:48

Evidence note

Screenshots are real Edge browser captures from this computer, displaying saved command output, recorded agent artifacts and GitHub directly. They are not native terminal captures. Captions explain each image. Raw sources and actual capture times are included in docs/evidence/.

1. Command-line interface

Required command-line interface

Rayyan Qamar | 23i-0815 | Section A. Saved machine output displayed in Edge.

```
Captured UTC: 2026-10-25T09:46:33.643995+00:00
Command: D:\i230815_A_A2\.venv\Scripts\python.exe agent.py --help
Exit code: 0

usage: agent.py [-h] --repo REPO --output OUTPUT [--trace TRACE]
                [--max-steps MAX_STEPS] [--timeout TIMEOUT]

Evidence-based, read-only DevOps GitHub auditing agent

options:
  -h, --help            show this help message and exit
  --repo REPO           Public HTTPS GitHub repository URL
  --output OUTPUT       Destination JSON report
  --trace TRACE         Optional sanitized JSONL tool-call evidence
  --max-steps MAX_STEPS
                        Model/tool turns (default 32; maximum 100)
  --timeout TIMEOUT     Investigation seconds, excluding clone (default 1200)
```

The actual --help output shows the required --repo and --output arguments. The CLI runs without interactive prompts and exits nonzero when required setup or inspection fails.

2. Automated verification

Offline regression tests

Rayyan Qamar | 23i-0815 | Section A. Saved machine output displayed in Edge.

```
Captured UTC: 2026-10-25T09:46:42.756862+00:00
Command: D:\i230815_A_A2\.venv\Scripts\python.exe -m unittest discover -v
Exit code: 0

test_absence_claim_needs_all_inventory_pages (tests.test_agent.AgentTests.test_absence_claim_needs_all_inventory_pages) ... ok
test_dynamic_follow_up_uses_observation_and_preserves_signatures
(tests.test_agent.AgentTests.test_dynamic_follow_up_uses_observation_and_preserves_signatures) ... ok
test_healthy_empty_report_is_valid (tests.test_agent.AgentTests.test_healthy_empty_report_is_valid) ... ok
test_invalid_evidence_is_returned_for_correction (tests.test_agent.AgentTests.test_invalid_evidence_is_returned_for_correction) ... ok
test_malformed_provider_calls_fail_cleanly (tests.test_agent.AgentTests.test_malformed_provider_calls_fail_cleanly) ... ok
test_missing_file_uses_null_and_duplicates_collapsed (tests.test_agent.AgentTests.test_missing_file_uses_null_and_duplicates_collapsed) ... ok
test_no_report_when_budget_exhausted (tests.test_agent.AgentTests.test_no_report_when_budget_exhausted) ... ok
test_no_static_scanner_fallback_on_provider_failure (tests.test_agent.AgentTests.test_no_static_scanner_fallback_on_provider_failure) ... ok
test_report_contract_and_citation_validation (tests.test_agent.AgentTests.test_report_contract_and_citation_validation) ... ok
test_submission_cannot_share_turn_with_uninterpreted_read (tests.test_agent.AgentTests.test_submission_cannot_share_turn_with_uninterpreted_read) ... ok
test_unknown_tool_can_be_recovered (tests.test_agent.AgentTests.test_unknown_tool_can_be_recovered) ... ok
test_atomic_report_and_non_ascii (tests.test_cli.CLITests.test_atomic_report_and_non_ascii) ... ok
test_complete_cli_flow_with_real_git_tools_and_fake_provider (tests.test_cli.CLITests.test_complete_cli_flow_with_real_git_tools_and_fake_provider) ...
ok
test_fatal_error_preserves_previous_report (tests.test_cli.CLITests.test_fatal_error_preserves_previous_report) ... ok
test_invalid_url_nonzero_and_no_output (tests.test_cli.CLITests.test_invalid_url_nonzero_and_no_output) ... ok
test_missing_key_nonzero_without_clone (tests.test_cli.CLITests.test_missing_key_nonzero_without_clone) ... ok
test_same_output_and_trace_rejected (tests.test_cli.CLITests.test_same_output_and_trace_rejected) ... ok
test_authentication_error_never_prints_provider_body (tests.test_provider.ProviderTests.test_authentication_error_never_prints_provider_body) ... ok
test_missing_key_and_model_url_injection_rejected (tests.test_provider.ProviderTests.test_missing_key_and_model_url_injection_rejected) ... ok
test_native_tool_call_is_passed_through_with_signature (tests.test_provider.ProviderTests.test_native_tool_call_is_passed_through_with_signature) ... ok
test_network_errors_and_malformed_payloads (tests.test_provider.ProviderTests.test_network_errors_and_malformed_payloads) ... ok
test_rate_limit_honors_bounded_retry_after (tests.test_provider.ProviderTests.test_rate_limit_honors_bounded_retry_after) ... ok
test_transient_error_retried (tests.test_provider.ProviderTests.test_transient_error_retried) ... ok
test_truncated_response_is_fatal (tests.test_provider.ProviderTests.test_truncated_response_is_fatal) ... ok
test_common_secret_formats_and_remembered_values (tests.test_safety.SafetyTests.test_common_secret_formats_and_remembered_values) ... ok
test_env_loader_does_not_execute_and_environment_wins (tests.test_safety.SafetyTests.test_env_loader_does_not_execute_and_environment_wins) ... ok
test_environment_references_and_placeholders_preserved (tests.test_safety.SafetyTests.test_environment_references_and_placeholders_preserved) ... ok
test_environment_secret_is_scrubbed_everywhere (tests.test_safety.SafetyTests.test_environment_secret_is_scrubbed_everywhere) ... ok
test_public_url_normalization (tests.test_safety.SafetyTests.test_public_url_normalization) ... ok
test_rejects_credentials_other_hosts_and_ambiguous_paths (tests.test_safety.SafetyTests.test_rejects_credentials_other_hosts_and_ambiguous_paths) ... ok
test_workflow_permissions_and_inherited_secrets_are_not_credentials
(tests.test_safety.SafetyTests.test_workflow_permissions_and_inherited_secrets_are_not_credentials) ... ok
test_git_log_and_target_unchanged (tests.test_tools.ToolsTests.test_git_log_and_target_unchanged) ... ok
test_invalid_paths_and_oversized_reads_are_tool_errors (tests.test_tools.ToolsTests.test_invalid_paths_and_oversized_reads_are_tool_errors) ... ok
test_inventory_hidden_paths_and_pagination (tests.test_tools.ToolsTests.test_inventory_hidden_paths_and_pagination) ... ok
test_literal_search_and_skips_are_explicit (tests.test_tools.ToolsTests.test_literal_search_and_skips_are_explicit) ... ok
test_multiline_private_key_preserves_line_numbers (tests.test_tools.ToolsTests.test_multiline_private_key_preserves_line_numbers) ... ok
test_numbered_read_and_evidence_ledger (tests.test_tools.ToolsTests.test_numbered_read_and_evidence_ledger) ... ok
test_read_pagination (tests.test_tools.ToolsTests.test_read_pagination) ... ok
test_secret_removed_before_tools_return (tests.test_tools.ToolsTests.test_secret_removed_before_tools_return) ... ok
test_symlinks_are_not_followed (tests.test_tools.ToolsTests.test_symlinks_are_not_followed) ... ok
test_unknown_tools_and_argument_types (tests.test_tools.ToolsTests.test_unknown_tools_and_argument_types) ... ok

----------------------------------------------------------------------
Ran 41 tests in 8.863s

OK
```

This capture displays the saved unittest run. Tests cover Git inspection, paths and symlinks, redaction, dynamic follow-up calls, report validation, provider failures, healthy empty reports and CLI behavior. These are offline tests with fake model responses, separate from the live evaluation.

3. Code checks

Lint and security checks

Rayyan Qamar | 23i-0815 | Section A. Saved machine output displayed in Edge.

```
Captured UTC: 2026-10-25T09:46:42.862694+00:00
Command: D:\i230815_A_A2\.venv\Scripts\python.exe -m ruff check .
Exit code: 0

All checks passed!
```

Ruff checks passed on the project source. Formatting was also checked and its raw transcript is included. GitHub Actions repeats lint, formatting and the offline suite on Python 3.11, 3.12, 3.13 and 3.14.

4. Live evaluation

Measured live evaluation results

Rayyan Qamar | 23i-0815 | Section A. Saved machine output displayed in Edge.

```
Live Gemini evaluation on LOCAL SYNTHETIC repositories.
Not instructor hidden repositories. Scores are provisional file/line matches.

OBVIOUS | model=gemini-3.1-flash-lite
Detected 2/2 reference defects; reported 2 findings.
Target unchanged: True | time: 39.29 seconds
Missed: none

SUBTLE | model=gemini-3.1-flash-lite
Detected 1/2 reference defects; reported 1 findings.
Target unchanged: True | time: 29.45 seconds
Missed: PR title is interpolated directly into shell code

HEALTHY | model=gemini-3.1-flash-lite
Detected 0/0 reference defects; reported 0 findings.
Target unchanged: True | time: 35.27 seconds
Missed: none
```

The real Gemini model inspected three local synthetic repositories. It detected both obvious defects and the privileged PR workflow defect, and reported no findings on the healthy repository. It missed the separate PR-title shell injection. These small local results do not estimate hidden-test performance.

Fixture	Matched / expected	Findings	Unchanged
obvious	2 / 2	2	True
subtle	1 / 2	1	True
healthy	0 / 0	0	True

5. Public GitHub audit

Public repository audit and dynamic tool trace

Rayyan Qamar | 23i-0815 | Section A. Saved machine output displayed in Edge.

```
PUBLIC GITHUB AUDIT — recorded live model/tool interaction
{
  "event": "start",
  "repository": "https://github.com/psf/requests",
  "commit": "611c6162cbc4ac2020a2f91c7cfa4f3abf9bbb60",
  "model": "gemini-3.1-flash-lite",
  "timestamp": "2026-10-25T06:29:48.077291+00:00"
}

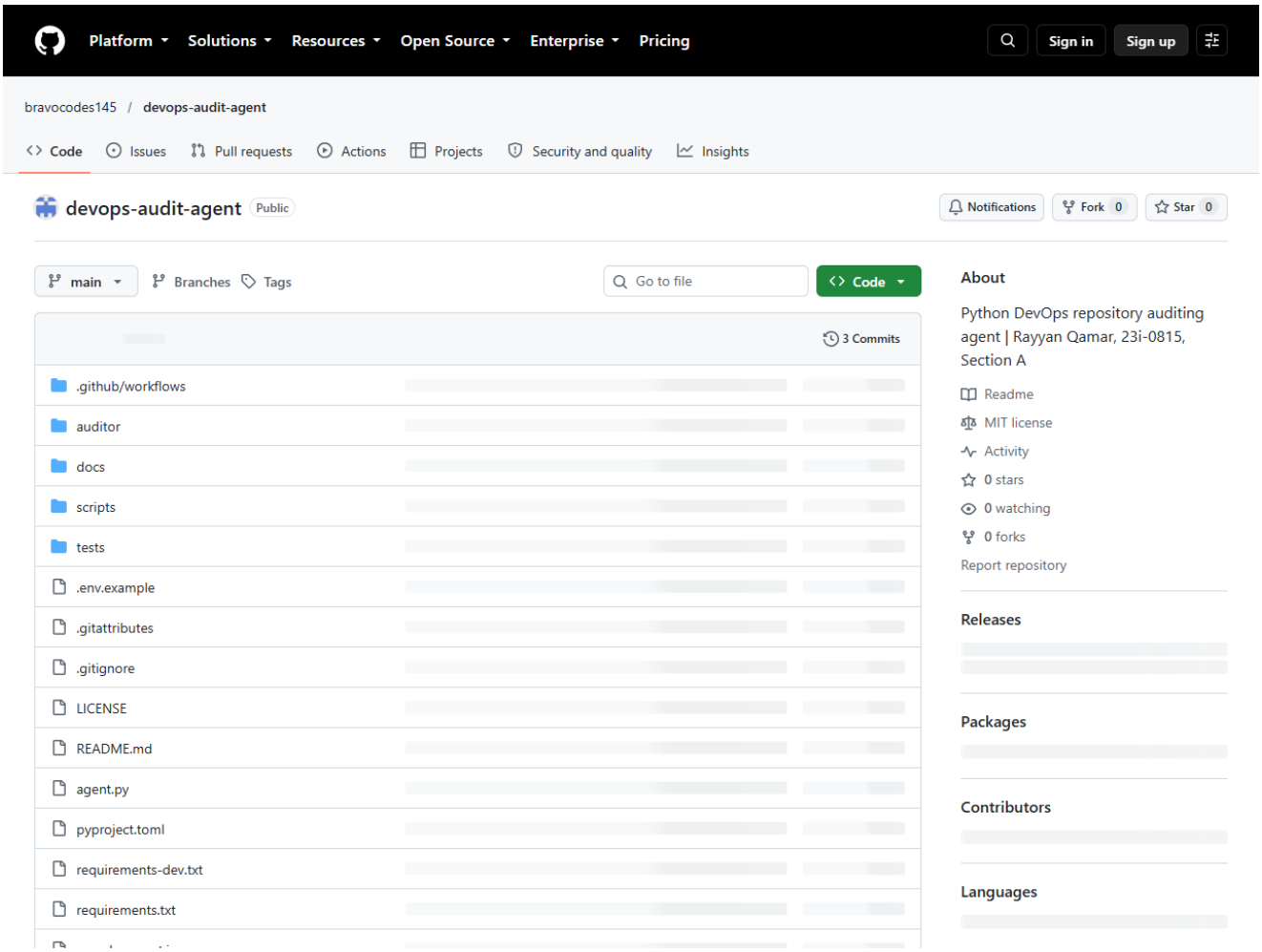
Turn 1: list_files({"limit": 100})
Turn 2: read_file({"path": ".github/workflows/publish.yml"})
Turn 3: read_file({"path": ".github/workflows/run-tests.yml"})
Turn 4: read_file({"path": "Makefile"})
Turn 5: read_file({"path": "requirements-dev.txt"})
Turn 6: read_file({"path": "pyproject.toml"})
Turn 7: read_file({"path": ".github/workflows/lint.yml"})
Turn 8: read_file({"path": ".pre-commit-config.yaml"})
Turn 9: read_file({"path": ".github/workflows/codeql-analysis.yml"})
Turn 10: submit_report(final JSON report)

{
  "event": "complete",
  "steps": 10,
  "violations": 0,
  "elapsed_seconds": 61.28,
  "timestamp": "2026-10-25T06:30:49.353244+00:00"
}

Actual CLI output artifact:
{
  "repository": "https://github.com/psf/requests",
  "violations": []
}
```

The required CLI audited psf/requests. The recorded trace shows model-selected follow-up reads and a completed JSON report with 0 findings. The target commit and timing are saved in docs/sample.trace.jsonl. An earlier run produced an unsupported warning; the unedited baseline is preserved and explained in the README.

6. Public submission repository



This is a direct browser screenshot of the public GitHub repository. The executable agent, tests, installation instructions, authentic JSON example and this PDF are submitted together. Only the repository URL is needed in the course submission field.